

Manual Prático de Segurança de IA

Edição IBM Cloud

Um guia acessível para iniciantes sobre fundamentos de nuvem, cargas de trabalho de IA, RAG, agentes, MCP, governança, testes, monitoramento e resposta a incidentes.

Alberto (AI) Leiva

Versão 1.0 | Julho de 2026

Use somente em contas, projetos e sistemas que você possui ou está autorizado a administrar. Capacidade técnica nunca constitui autorização.

Índice

No Microsoft Word, clique com o botão direito do mouse na tabela e selecione Atualizar Campo.

Índice	2
Como usar este manual	3
Fundamentos de Nuvem e IA	3
Mapa de controle da plataforma	3
Responsabilidade Compartilhada e Modelagem de Ameaças	4
Design de conta e landing zone seguros	4
Identidade, Acesso e Identidades Não Humanas	5
Segurança de Rede e Borda	5
Proteção de Dados, Criptografia e Privacidade	5
Registro, Detecção e Postura de Segurança	6
Carga de trabalho, contêineres e segurança da cadeia de suprimentos	6
Gestão do Ciclo de Vida da IA e dos Riscos de Modelo	6
Inteligência Artificial Generativa e Segurança de Prompts	7
Segurança de RAG	7
Agentes de IA, Ferramentas e MCP	7
Testes e Red Teaming	8
Mapeamento de Governança, Conformidade e Controle	8
Resposta a Incidentes para IA em Nuvem	8
Laboratório Prático de Sandbox	9
Pacote de evidências	9
Evidências de Auditoria e Listas de Verificação Operacionais	9
Prática de Carreira e Orientação Final	10
Glossário	10
Recursos oficiais e estudos adicionais	11
Apêndice: Linha de Base de Controle Mínima	11

Como usar este manual

Este manual ensina uma abordagem repetível para proteger soluções de IA na IBM Cloud. Ele começa com fundamentos de nuvem e avança por identidade, dados, redes, IA generativa, geração aumentada por recuperação (RAG), agentes, Model Context Protocol (MCP), governança e operações.

Os nomes dos produtos e as telas dos consoles mudam. A habilidade essencial é aprender por que um controle existe, qual risco ele reduz, como verificá-lo e quais evidências comprovam seu funcionamento. Sempre confirme a disponibilidade regional, o licenciamento e a documentação atualizada antes de usar o produto.

- Se você é iniciante em segurança na nuvem, leia os capítulos na ordem indicada.
- Profissionais experientes podem usar as listas de verificação e as tabelas de controle como referência de trabalho.
- Pratique em um ambiente isolado, utilizando dados sintéticos ou públicos.
- Registre as decisões, os responsáveis, as aprovações e os resultados dos testes à medida que trabalha.

Fundamentos de Nuvem e IA

A IBM Cloud fornece serviços de computação, armazenamento, rede, bancos de dados, identidade, monitoramento e IA. Um sistema de IA combina esses componentes de nuvem com modelos, prompts, dados, código, interfaces e pessoas. Proteger apenas o modelo deixa a maior parte do sistema desprotegida.

A estrutura administrativa principal inclui enterprise, conta, grupos de recursos, regiões e instâncias de serviço. Use essa estrutura para separar produção de desenvolvimento, restringir privilégios, acompanhar custos e estabelecer limites de política ao redor de cargas de trabalho sensíveis.

Secure AI request path

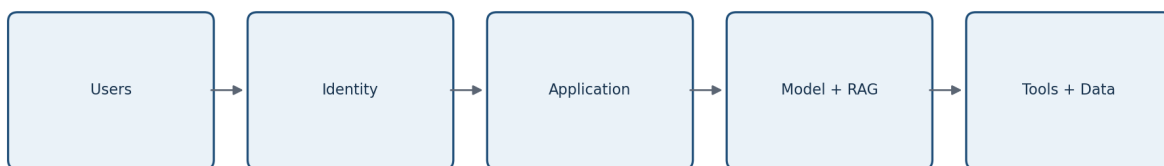


Figura 1. Os controles de segurança abrangem todo o caminho da solicitação de IA.

Mapa de controle da plataforma

Camada	Capacidade da plataforma	Objetivo de segurança
Organização	Enterprise, conta, grupos de recursos, regiões e instâncias de serviço	Ambientes, propriedade e âmbito de aplicação das políticas distintos.
Identidade	Políticas do IBM Cloud IAM, grupos	Federação, MFA, privilégio mínimo

Camada	Capacidade da plataforma	Objetivo de segurança
	de acesso, perfis confiáveis, IDs de serviço e chaves de API	e identidade de carga de trabalho.
Rede	IBM Cloud VPCs, sub-redes, grupos de segurança, ACLs de rede, Transit Gateway, Direct Link e Cloud Internet Services	Caminhos privados, entrada controlada e saída explícita.
Chaves e segredos	IBM Key Protect, Hyper Protect Crypto Services e Secrets Manager	Responsabilidade pelas chaves, rodízio, segregação de funções e recuperação de segredos.
Registros	IBM Cloud Logs, Activity Tracker Event Routing, Monitoring e Event Notifications	Provas protegidas, detecção e investigação.
Postura	IBM Cloud Security and Compliance Center e Workload Protection	Análises contínuas de configuração e carga de trabalho.
Plataforma de IA	IBM watsonx.ai, watsonx.governance e watsonx.data	Ciclo de vida, avaliação, implementação e governança do modelo.

- IaaS: o cliente gerencia sistemas operacionais, aplicativos, identidades e dados.
- PaaS: o provedor gerencia a maior parte do ambiente de execução, enquanto o cliente ainda gerencia o acesso, a configuração e os dados.
- SaaS: o provedor opera o aplicativo, mas o cliente continua responsável pelos usuários, compartilhamento, uso de dados e decisões de negócios.
- Os serviços de IA acrescentam responsabilidades relacionadas ao comportamento do modelo, ao tratamento de prompts, à avaliação e à supervisão humana.

Responsabilidade Compartilhada e Modelagem de Ameaças

Os provedores de nuvem protegem as instalações e a plataforma de serviços subjacentes. Os clientes protegem suas tenancies, configurações, identidades, cargas de trabalho, dados e uso dos resultados de IA. Os serviços gerenciados reduzem o trabalho operacional, mas não eliminam a responsabilidade.

A modelagem de ameaças questiona o que você está construindo, o que pode dar errado, quais controles existem e como você saberá quando eles falharem. Repita o processo sempre que o modelo, a fonte de dados, as permissões da ferramenta, o padrão de implantação ou a finalidade de negócios mudarem.

- Mapear os limites de confiança entre usuários, aplicativos, modelos, repositórios de vetores, ferramentas e serviços externos.
- Identificar entradas, saídas, credenciais, embeddings, logs e dados de treinamento sensíveis.
- Considere uso indevido, injeção de prompt, autonomia excessiva, envenenamento de dados, tratamento inseguro de saídas e negação de serviço.
- Atribua um responsável e um método de verificação mensurável a cada medida de mitigação importante.

Design seguro de conta e landing zone

Uma landing zone segura estabelece a organização de contas, a integração de identidade, os padrões de rede, o logging, a criptografia, os guardrails e o acesso para resposta a incidentes antes que as equipes implantem cargas de trabalho. Na IBM Cloud, organize os recursos por enterprise, conta, grupos de recursos, regiões e instâncias de serviço.

Separe os ambientes de produção, desenvolvimento, ferramentas de segurança e serviços compartilhados. Centralize os logs de segurança em um local que os administradores de cargas de trabalho não possam alterar sem autorização. Utilize infraestrutura como código para que as configurações importantes sejam revisáveis e replicáveis.

- Documente a titularidade da conta e os contatos de emergência.
- Exigir autenticação multifator para administradores humanos.
- Crie limites separados para produção e não produção.
- Habilite a coleta de auditorias em toda a organização antes da integração de novos aplicativos.
- Defina regiões, serviços, imagens, padrões de gerenciamento de chaves e regras de etiquetagem aprovados.
- Teste a restauração do backup e o acesso de emergência.

Identidade, Acesso e Identidades Não Humanas

As políticas do IBM Cloud IAM, os grupos de acesso, os perfis confiáveis, os IDs de serviço e as chaves de API controlam quem pode acessar os recursos e o que pode acessar. Contas humanas devem usar federação e MFA. Sempre que possível, as cargas de trabalho devem usar identidades nativas da plataforma e de curta duração, em vez de chaves de API incorporadas.

Identidades não humanas incluem contas de serviço, IDs de serviço, identidades de carga de trabalho, identidades de agentes, credenciais de CI/CD e tokens de integração. Elas frequentemente acumulam privilégios excessivos e sobrevivem aos seus proprietários, portanto, exigem inventário, controle de propriedade, rotação e monitoramento.

- Conceda o mínimo privilégio possível, dentro do escopo de recursos práticos mais restrito.
- Separe as funções de administração, implantação, execução e auditoria.
- Evite contas compartilhadas e credenciais com longa duração.
- Exigir aprovação para permissões de alto risco e acesso à produção.
- Analise identidades inativas, permissões não utilizadas e chaves órfãs.
- Atribua a cada agente de IA uma identidade própria e limite individualmente cada ferramenta que ele possa chamar.

Segurança de rede e de borda

Use IBM Cloud VPCs, sub-redes, grupos de segurança, ACLs de rede, Transit Gateway, Direct Link e Cloud Internet Services para criar limites de rede em camadas. Endpoints privados reduzem a exposição, mas “privado” não significa automaticamente “confiável”. Inspecione o tráfego, limite as rotas e aplique controles de identidade mesmo dentro de redes privadas.

Aplicações de IA frequentemente acessam endpoints de modelos, bancos de dados, APIs de SaaS e ferramentas. Crie uma política de saída explícita para que um prompt ou agente comprometido não possa enviar informações livremente para a internet.

- Por padrão, negar o acesso de entrada e permitir apenas fluxos documentados.
- Utilize conectividade de serviço privado onde for compatível.

- Restrinja o acesso administrativo por meio de um bastião gerenciado ou acesso privado aprovado.
- Proteja endpoints públicos com WAF, controles de DDoS, limites de taxa e defesas contra bots.
- Registre eventos de fluxo e de borda e alerte sobre destinos ou volumes incomuns.
- Teste o comportamento de DNS, roteamento e failover.

Proteção de dados, criptografia e privacidade

Classifique os dados antes que cheguem ao IBM Cloud Object Storage, a bancos de dados, ao watsonx.data e ao Knowledge Catalog, a prompts de modelos, a tarefas de fine-tuning ou a índices vetoriais. Use IBM Key Protect, Hyper Protect Crypto Services e Secrets Manager para proteger chaves e segredos. A criptografia é necessária, mas as decisões de acesso, retenção e exclusão são igualmente importantes.

Os embeddings podem preservar significados sensíveis mesmo quando não reproduzem o texto original com exatidão. Trate os repositórios de vetores, os conjuntos de dados de avaliação, os históricos de prompts e as saídas do modelo de acordo com a classificação dos seus dados de origem.

- Colete somente os dados necessários para a finalidade aprovada.
- Bloqueie segredos e dados regulamentados em prompts, salvo quando houver aprovação explícita.
- Utilize chaves gerenciadas pelo cliente quando o risco, a regulamentação ou o contrato assim o exigirem.
- Separe os administradores de chaves dos administradores de dados.
- Defina os critérios de retenção e exclusão defensável para prompts, outputs, logs e embeddings.
- Teste a criptografia de backup e as permissões de restauração.

Registro, detecção e postura de segurança

IBM Cloud Logs, Activity Tracker Event Routing, Monitoring e Event Notifications fornecem evidências operacionais e de segurança. IBM Cloud Security and Compliance Center e Workload Protection ajudam a identificar fragilidades de configuração e riscos das cargas de trabalho. Encaminhe eventos de alto valor para um repositório central protegido e, quando apropriado, para um SIEM.

Não registre prompts completos nem documentos recuperados por padrão. O logging deve equilibrar as necessidades de investigação com a privacidade e o risco de exposição de segredos. Prefira identificadores, hashes, classificações, decisões de política e trechos redigidos.

- Acessos administrativos e alterações de política
- Eventos do ciclo de vida de credenciais, chaves e segredos
- Alterações de rede, firewall e exposição pública
- Atividade de invocação de endpoint, agente e ferramenta do modelo
- Bloqueios de guardrail, detecções de injeção de prompt e eventos de saída insegura
- Acesso a dados, exportações, exclusões e volume incomum
- Falhas no pipeline de logging e alterações de retenção

Carga de trabalho, contêineres e segurança da cadeia de suprimentos

Red Hat OpenShift on IBM Cloud, IBM Cloud Kubernetes Service, Container Registry e Code Engine podem hospedar aplicações de IA e serviços de apoio. Proteja o pipeline de build com o mesmo cuidado aplicado ao ambiente de execução: um cluster confiável não compensa um pacote, modelo ou imagem de contêiner malicioso.

Utilize artefatos assinados, registries controlados, listas de materiais de software, varredura de vulnerabilidades e aprovações de implantação. Fixe dependências e versões de modelos sempre que possível e documente a origem e a licença de cada modelo e conjunto de dados.

- Use imagens base mínimas e compatíveis e execute como usuário não root.
- Analisar código, dependências, imagens, modelos de infraestrutura e segredos.
- Assinar os artefatos de lançamento e verificar as assinaturas durante a implantação.
- Aplicar políticas de admissão e restringir o acesso a contêineres privilegiados.
- Utilize identidades de compilação e de execução separadas.
- Monitore o desvio em relação à configuração aprovada e às versões do modelo.

Gestão do Ciclo de Vida da IA e dos Riscos de Modelo

IBM watsonx.ai, watsonx.governance e watsonx.data apoiam partes do ciclo de vida da IA. A segurança começa com um caso de uso documentado, um responsável definido e uma classificação de risco — não com um endpoint de modelo.

Avalie a qualidade e a segurança em relação à população e ao ambiente pretendidos. Um modelo que apresenta bom desempenho em uma demonstração pode falhar com idiomas diferentes, instruções adversas, dados incompletos ou pressão real de negócios.

- Defina a finalidade, os usos proibidos e a autoridade de decisão humana.
- Registre o fornecedor e a versão do modelo, as fontes de dados, a licença e as limitações conhecidas.
- Estabeleça limites de aceitação mensuráveis para precisão, segurança, privacidade, latência e custo.
- Teste vieses, alucinações, injeção de prompt, vazamento de dados e casos de abuso.
- Aprovar a liberação por meio de análise independente de riscos e negócios.
- Monitore após a implantação e defina os gatilhos de reversão.

Continuous AI security lifecycle

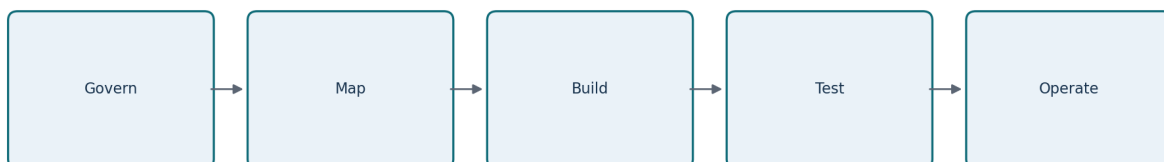


Figura 2. A governança e os testes continuam ao longo de todo o ciclo de vida.

Inteligência Artificial Generativa e Segurança de Prompts

Um prompt de sistema não é um limite de segurança. Atacantes podem usar injeção de prompt direta ou indireta para manipular instruções, revelar dados ou acionar ferramentas. Trate toda entrada do usuário e todo conteúdo recuperado como não confiáveis.

Guardrails reduzem o risco, mas não garantem comportamento seguro. Combine validação de entrada, filtragem de conteúdo, permissões restritas, validação de saída, monitoramento e confirmação humana para ações de impacto significativo.

- Separe as instruções confiáveis do conteúdo não confiável.
- Não insira segredos em prompts ou instruções do sistema.
- Restrinja os formatos de saída e valide-os antes do uso posterior.
- Use listas de permissões para ferramentas, destinos e fontes de dados.
- Aplique limites de taxa a operações caras ou sensíveis.
- Realize red teaming de ataques multilíngues, codificados, ofuscados e indiretos.

Segurança de RAG

RAG fundamenta as respostas do modelo em documentos selecionados e também cria um sistema de segurança para recuperação de dados. O controle de acesso deve ser aplicado antes da recuperação, não depois de o modelo ter visto o conteúdo.

Um documento envenenado pode conter instruções ocultas ou persuasivas. Proteja a ingestão, preserve a proveniência, examine o conteúdo, imponha autorização no nível do documento e exiba citações para que os usuários possam verificar a resposta.

- Aprove e inventarie os repositórios de origem.
- Examine a ingestão em busca de malware, segredos, instruções semelhantes a prompts e formatos não compatíveis.
- Preserve como metadados a origem, o responsável, a classificação, a versão e o horário de ingestão.
- Filtre os resultados pela identidade do solicitante e pela finalidade comercial.
- Limite o tamanho do contexto e impeça a recuperação entre tenancies.
- Avalie a precisão da recuperação, a autorização e a exatidão das citações.

Agentes de IA, Ferramentas e MCP

Os agentes combinam raciocínio baseado em modelos com memória e ferramentas. O MCP padroniza as conexões entre clientes de IA e servidores que expõem recursos, prompts ou ferramentas. Essa conveniência aumenta a importância da autenticação, autorização e limites de confiança explícitos.

Considere todos os servidores e agentes do MCP como softwares de integração privilegiados. Uma ferramenta de busca de documentos somente leitura apresenta um risco diferente de uma ferramenta que envia e-mails, altera regras de firewall ou executa código.

- Inventarie cada agente, ferramenta, servidor MCP, responsável e fluxo de dados.
- Autentique o cliente e o servidor e use transporte criptografado.
- Atribua a cada agente uma identidade dedicada com privilégios mínimos.
- Exija confirmação para ações irreversíveis, externas ou de alto impacto.
- Valide os parâmetros e as saídas da ferramenta; nunca execute cegamente texto gerado pelo modelo.

- Registre a seleção da ferramenta, os argumentos, a decisão de política, o resultado e a aprovação do usuário.
- Desative as ferramentas não utilizadas e forneça um botão de desligamento imediato.

Testes e Red Teaming

Os testes devem demonstrar se os controles funcionam, e não apenas se o modelo responde a perguntas comuns. Utilize ambientes aprovados e dados sintéticos. Nunca teste sistemas de terceiros sem autorização por escrito.

Combine a avaliação automatizada com a revisão humana. Ferramentas como Promptfoo, garak, PyRIT, Giskard e Inspect AI podem ajudar a organizar os testes, mas os resultados exigem interpretação e configuração segura.

- Crie um plano de testes baseado em ameaças e critérios de sucesso.
- Inclua casos normais, extremos, de uso indevido e adversariais.
- Teste em diferentes idiomas e perfis de usuário.
- Verifique o comportamento do modelo e os controles de acesso relacionados.
- Registre as instruções, versões, configurações, resultados e decisões dos revisores.
- Teste novamente após alterações no modelo, nos prompts, nos dados, nas ferramentas ou nas políticas.

Mapeamento de Governança, Conformidade e Controle

Use estruturas de governança para criar uma linguagem comum e, em seguida, adapte os controles ao sistema real. NIST AI RMF, ISO/IEC 42001, ISO/IEC 27001, NIST CSF 2.0, requisitos de privacidade e regras setoriais podem coexistir em um único programa de controles orientado por evidências.

Um mapeamento não é prova de conformidade. As evidências devem demonstrar que um controle foi projetado adequadamente, atribuído a um responsável e operado ao longo do tempo.

- Governança: propriedade, política, apetite ao risco e responsabilidade.
- Mapa: contexto, pessoas afetadas, dados, dependências e impactos.
- Critérios de avaliação: qualidade, segurança, privacidade, imparcialidade, resiliência e custo.
- Gerenciar: priorizar o tratamento, aprovar o risco residual e monitorar as mudanças.
- Manter um inventário de modelos/sistemas, um registro de riscos, uma biblioteca de controles e um repositório de evidências.

Resposta a incidentes para IA na nuvem

Incidentes de IA podem envolver credenciais comprometidas, dados expostos, resultados inseguros, fontes de conhecimento contaminadas, automação abusiva, custos inesperados ou alterações no provedor do modelo. Amplie o processo normal de incidentes para capturar o contexto do modelo e do prompt.

Preserve as evidências sem coletar mais conteúdo sensível do que o necessário. Coordene segurança, privacidade, questões legais, proprietários dos modelos, proprietários das empresas e comunicações de acordo com a gravidade da situação.

- Triagem: confirmar o escopo, as identidades afetadas, os dados, os modelos, as ferramentas e os usuários.

- Conter: revogar credenciais, isolar endpoints, desativar ferramentas, suspender a ingestão ou reverter um modelo.
- Preservar: proteger registros, configurações, prompts, saídas, aprovações e versões relevantes.
- Erradicar: remover conteúdo malicioso, bloquear caminhos de acesso e corrigir a automação.
- Recuperar: validar os controles, monitorar de perto e obter a aprovação da empresa.
- Aprenda: atualize testes, controles, documentação e treinamento.

Laboratório Prático de Sandbox

Este laboratório cria uma pequena linha de base de segurança, não produtiva, na IBM Cloud. Use somente dados sintéticos e os serviços elegíveis de menor custo. Exclua os recursos ao terminar e verifique se os logs permanecem disponíveis pelo período necessário.

O objetivo é praticar segurança baseada em evidências: cada configuração deve gerar uma captura de tela, uma política exportada, um evento de log ou um resultado de teste que outra pessoa possa revisar.

- Crie um limite não produtivo dedicado usando enterprise, conta, grupos de recursos, regiões e instâncias de serviço; adicione tags de responsável, finalidade, ambiente e classificação de dados.
- Federe ou proteja o administrador com MFA; crie uma conta separada para uso diário com privilégios limitados.
- Configure um padrão de rede privada com IBM Cloud VPCs, sub-redes, grupos de segurança, ACLs de rede, Transit Gateway, Direct Link e Cloud Internet Services; documente os fluxos de entrada e saída permitidos.
- Habilite IBM Cloud Logs, Activity Tracker Event Routing, Monitoring e Event Notifications e encaminhe eventos administrativos importantes para um armazenamento protegido.
- Configure IBM Key Protect, Hyper Protect Crypto Services e Secrets Manager; armazene um segredo de teste e recupere-o por meio de uma identidade de carga de trabalho, em vez de incorporá-lo ao código.
- Habilite ou revise IBM Cloud Security and Compliance Center e Workload Protection; investigue uma constatação e registre as evidências de correção.
- Implante um experimento mínimo de IA usando IBM watsonx.ai, watsonx.governance e watsonx.data, com dados sintéticos e sem ferramentas irreversíveis.
- Crie dez testes normais e dez testes adversários, incluindo injeção de prompts, solicitações de dados sensíveis e saída malformada.
- Analise custos, exposição pública, identidades, logs e constatações; exporte um pequeno pacote de evidências.
- Exclua os recursos temporários, revogue as credenciais de teste e confirme se os registros esperados permanecem disponíveis.

Pacote de evidências

- Diagrama de arquitetura
- Política de identidade exportada
- Resumo das regras de rede
- Prova de registro
- Evidências de configuração de chave/segredo
- Constatação de postura e correção
- Relatório de testes de IA
- Registro de limpeza

Evidências de auditoria e listas de verificação operacionais

Boas evidências são datadas, atribuíveis, reproduzíveis e vinculadas a um controle. Uma captura de tela isolada pode omitir escopo ou histórico; combine-a com configurações exportadas, logs, tickets, aprovações e resultados de testes.

Revise as evidências com frequência proporcional ao risco. Agentes de alto impacto e sistemas de produção sensíveis exigem revisão de acesso, testes e monitoramento mais frequentes do que uma demonstração com dados públicos.

- Arquitetura atual e diagrama de fluxo de dados
- Inventário de modelos, conjuntos de dados, agentes, ferramentas e identidades não humanas
- Modelo de avaliação de risco e ameaças aprovado
- Políticas de acesso e resultados de revisões periódicas
- Registros do ciclo de vida de chaves, segredos e certificados
- Resultados sobre configuração e postura de segurança
- Resultados de avaliação e red teaming, com correção
- Exercícios de incidentes, testes de recuperação e lições aprendidas.

Prática de Carreira e Orientação Final

A segurança de IA em nuvem é aprendida ao conectar arquitetura, identidade, dados, monitoramento, testes e governança. Desenvolva pequenos projetos autorizados e publique diagramas sanitizados, mapeamentos de controles e lições aprendidas, em vez de credenciais ou capturas de tela sensíveis.

Ao apresentar este trabalho profissionalmente, explique a finalidade de negócio, os principais riscos, as decisões, as evidências e o plano de melhoria. Empregadores valorizam julgamento claro e comunicação tanto quanto familiaridade com consoles de produtos.

- Nunca afirme ter experiência em produção que você não possui.
- Descreva o que você projetou, configurou, testou ou revisou.
- Mantenha um diário de laboratório e modelos com controle de versão.
- Use treinamentos do fornecedor, documentação oficial e contas seguras para prática.
- Ensine aos outros; explicar um controle é uma das melhores maneiras de testar a compreensão.

Glossário

Termo	Significado
Agente de IA	Um sistema que utiliza um modelo para planejar ou selecionar ações e invocar ferramentas.
Embedding	Uma representação numérica usada para comparar a similaridade semântica.
Guardrail	Uma política ou controle técnico destinado a restringir entradas, saídas ou ações.
Alucinação	Resultados aparentemente plausíveis, mas sem

Termo	Significado
	suporte ou incorretos.
MCP	Protocolo de Contexto de Modelo; um padrão para conectar clientes de IA a recursos, instruções e ferramentas.
Identidade não humana	Uma identidade usada por software, carga de trabalho, serviço, pipeline ou agente.
injeção de prompt	Instruções não confiáveis destinadas a alterar o comportamento do modelo ou a fazer uso indevido de recursos conectados.
RAG	Geração aumentada por recuperação; adição de material recuperado ao contexto do modelo.
Repositório vetorial	Um sistema que indexa e recupera embeddings.
Confiança Zero	Uma abordagem de segurança que verifica explicitamente, limita o acesso e pressupõe a ocorrência de violações.

Recursos oficiais e estudos adicionais

As características, nomes, preços e disponibilidade regional dos produtos podem sofrer alterações. Utilize estes pontos de partida oficiais e verifique a documentação aplicável à sua conta e região.

- [Segurança e conformidade da IBM Cloud — https://cloud.ibm.com/docs/security-compliance](https://cloud.ibm.com/docs/security-compliance)
- [IBM Cloud IAM — https://cloud.ibm.com/docs/account?topic=account-iamoverview](https://cloud.ibm.com/docs/account?topic=account-iamoverview)
- [Security and Compliance Center — https://cloud.ibm.com/docs/security-compliance](https://cloud.ibm.com/docs/security-compliance)
- [Workload Protection — https://cloud.ibm.com/docs/workload-protection](https://cloud.ibm.com/docs/workload-protection)
- [IBM watsonx — https://www.ibm.com/docs/en/watsonx](https://www.ibm.com/docs/en/watsonx)
- [IBM Cloud Logs — https://cloud.ibm.com/docs/cloud-logs](https://cloud.ibm.com/docs/cloud-logs)
- [Estrutura de Gestão de Riscos de IA do NIST — https://www.nist.gov/itl/ai-risk-management-framework](https://www.nist.gov/itl/ai-risk-management-framework)
- [Estrutura de Segurança Cibernética do NIST 2.0 — https://www.nist.gov/cyberframework](https://www.nist.gov/cyberframework)
- [OWASP Top 10 para aplicações de LLM — https://genai.owasp.org/llm-top-10/](https://genai.owasp.org/llm-top-10/)
- [ATLAS MITRE — https://atlas.mitre.org/](https://atlas.mitre.org/)
- [Protocolo de Contexto de Modelo — https://modelcontextprotocol.io/](https://modelcontextprotocol.io/)

Este manual é um guia educativo, não constituindo aconselhamento jurídico nem substituindo o suporte do fornecedor, os requisitos contratuais ou uma avaliação formal de conformidade.

Apêndice: Linha de Base de Controle Mínima

Domínio	Expectativa mínima	Exemplo de evidência
Governança	Caso de uso aprovado, proprietário, nível de risco e usos proibidos	Registro de aprovação; inventário do sistema
Identidade	MFA, federação, privilégio mínimo e identidades de carga de trabalho separadas.	Exportação de políticas; revisão de acesso
Dados	Classificação, minimização, criptografia, retenção e exclusão.	Fluxo de dados; configurações principais; registro de retenção
Rede	Acesso privado, entrada restrita e saída controlada.	Diagrama; regras; evidência de fluxo
Segurança da IA	Resistência à injeção, validação de saída, guardrails e aprovação humana	Relatório de avaliação; configuração de políticas
RAG	Fontes aprovadas, proveniência e autorização antes da recuperação.	Inventário de origem; testes de acesso
Agentes/MCP	Lista de permissões de ferramentas, identidade dedicada, aprovação e mecanismo de desativação imediata	Inventário de ferramentas; registro de invocação; teste de desligamento
Operações	Registros centrais, alertas, plano de resposta, backup e reversão	Teste de alerta; exercício; evidência de recuperação